На правах рукописи

003459471

Немиткина Виктория Викторовна

АНАЛИЗ И УПРАВЛЕНИЕ РИСКАМИ В ОБЛАСТИ ЗАЩИТЫ ИНФОРМАЦИИ

Специальность 08.00.13 –
«Математические и инструментальные методы экономики»

АВТОРЕФЕРАТ

диссертации на соискание ученой степени
кандидата экономических наук

1 4 ЯНВ 2009

Москва – 2009

Работа выполнена в Московском государственном университете экономики, статистики и информатики (МЭСИ) на кафедре Прикладной математики.

Научный руководитель:	кандидат технических наук, доцент Мастяева Ирина Николаевна
Официальные оппоненты:	доктор экономических наук, профессор Хрусталев Евгений Юрьевич
	кандидат экономических наук Денисов Денис Владимирович
Ведущая организация:	Московский государственный открытый университет

Защита диссертации состоится «11» февраля 2009 г. в 14 часов на заседании диссертационного совета Д 212.151.01 в Московском государственном университете экономики, статистики и информатики по адресу: 119501, г. Москва, ул. Нежинская, д.7.

С диссертацией можно ознакомиться в библиотеке Московского государственного университета экономики, статистики и информатики.

Автореферат разослан «30» декабря 2008 г.

Ученый секретарь
диссертационного совета,
кандидат технических наук, доцент Мастяева И.Н.

ОБЩАЯ ХАРАКТЕРИСТИКА РАБОТЫ

Актуальность исследования

В последнее время быстрое развитие технологий передачи и обработки информации сделало ее одним из ценнейших ресурсов. На сегодняшний день информация приобретает уникальную ценность и является одним из критически важных ресурсов – это новые идеи, производственные, коммерческие секреты и т.д. Все это не могло не наложить свой отпечаток на ведение бизнеса на всех уровнях. Информация используется для принятия важных стратегических решений и от того, насколько она будет достоверна и актуальна, может зависеть дальнейшая судьба фирмы. Разглашение или утечка конфиденциальной коммерческой информации могут повлечь значительные финансовые убытки, а также негативно отразиться на имидже компании. Уничтожение одного или нескольких информационных ресурсов способно надолго парализовать деятельность целого предприятия. Поэтому, совершенно очевидно, что вопросы обеспечения безопасности информации сегодня являются ключевыми проблемами бизнеса. Наиболее актуальны эти вопросы для компаний, имеющих отношение к информационным технологиям, к банковскому сектору, к услугам связи, к инновационным проектам и т.п.

Таким образом, перед современным бизнесом остро встает задача обеспечения надежной защиты своих информационных ресурсов. Однако, как и любая другая защита, защита информации является делом крайне дорогостоящим, и далеко не всегда руководители предприятий осознают, что такие вложения являются крайне выгодными, позволяя существенно снизить потери, связанные с информационными рисками. Большинство публикаций, посвященных вопросам информационной безопасности, изобилуют техническими подробностями, при этом абсолютно упускают из виду проблему экономической целесообразности тех или иных решений. Так, основная масса существующих стандартов используют понятие "модели нарушителя", которое позволяет определить возможности злоумышленника, против которого направлена система защиты информации. Однако такой подход позволяет лишь оценить надежность системы и не учитывает ее стоимостные характеристики. Вместе с тем вопрос экономической эффективности является ключевым при принятии решений о выделении различных денежных сумм на реализацию отдельных программ и мероприятий по обеспечению информационной безопасности. На сегодняшний день наиболее распространенным способом решения данного вопроса является применение систем анализа рисков, позволяющих оценить риски в информационной системе и выбрать оптимальный по эффективности вариант контрмер.

В настоящее время существует целый ряд программных продуктов, ориентированных на оценку информационных рисков организаций. Однако подавляющее большинство из них рассматривают лишь риски, связанные с компьютерной подсистемой информационной инфраструктуры компании, оставляя в стороне бумажный документооборот, проблему защиты информации при телефонных и личных переговорах, а также другие процессы в организации, в

ходе которых происходит передача, обработка или хранение информации. Кроме того, такие программные продукты в своей работе используют лишь общие рекомендации по защите компьютерных сетей и часто не учитывают конкретных особенностей информационной инфраструктуры фирмы.

Все это зачастую "ставит в тупик" руководителей высшего звена, которые в последнее время, осознавая важность проблемы обеспечения информационной безопасности на предприятии, начинают уделять ей существенно больше внимания. Однако при этом далеко не всегда они могут обоснованно оценить объем денежных средств, необходимый для решения задач информационной безопасности. Кроме того, не менее важным является распределение данных средств между отдельными задачами, касающимися обеспечения защиты информации. Эта проблема, как правило, решается исключительно на основе интуитивных предположений руководителей подразделений без опоры на формальное обоснование экономической целесообразности данного решения.

Таким образом, актуальность данной работы обусловлена существующей на сегодняшний день потребностью в создании методик управления финансовыми активами в рамках решения задач обеспечения информационной безопасности и снижения уровня информационных рисков.

Цели и задачи исследования. Целью диссертационного исследования является построение методики анализа информационных рисков организации и оптимизация распределения средств, выделенных на реализацию мероприятий информационной безопасности.

В соответствии с указанными целями в работе поставлены и решены следующие задачи:

- классификация организаций по уровню требований, предъявляемых ими к информационной безопасности;
- сравнительный анализ существующих методик оценки информационных рисков и обзор основных стандартов в области защиты информации и управления рисками;
- обзор существующих инструментальных средств анализа и управления информационными рисками с целью выявления их основных характеристик, а также сильных и слабых сторон;
- выявление состава параметров, влияющих на оценку информационного риска;
- определение вида и свойств функции зависимости риска от средств, вложенных в мероприятия информационной безопасности;
- построение математической модели зависимости уровня информационного риска от объема денежных средств, выделяемых на решение задач информационной безопасности, а также распределения этих средств между отдельными направлениями обеспечения защиты;

- разработка методики оценки уровня риска для информационной инфраструктуры организации, а также подходов к оптимизации расходов на информационную безопасность;
- апробация разработанной методики при решении задачи анализа рисков для информационной системы ВУЗа.

Объект и предмет исследования. Объектом диссертационного исследования является информационная инфраструктура организации.

Предметом исследования выступают риски, возникающие в процессе обработки и хранения информации в организации, а также их зависимость от объемов финансирования мероприятий, связанных с защитой информации.

Теоретическая и методологическая основа исследования. Теоретическую и методологическую основу исследования составили труды отечественных и зарубежных ученых в предметных областях экономики, математики, информационной безопасности, риск-менеджмента, теории оптимального управления. В частности, разработки и исследования следующих российских авторов: Домарева В.В., Кононова А.А., Петренко С.А и Симонова С.В.

В работе также применялись:

- международные стандарты в области защиты информации и анализа информационных рисков (ISO 15408, ISO 17799, BSI и др.);
- руководящие документы Гостехкомиссии России;
- описания существующих как отечественных, так и зарубежных инструментальных средств анализа и управления информационными рисками (COBRA, CRAMM, Гриф и др.);
- нормативные и законодательные акты, принятые на территории Российской Федерации.

Научная новизна. Предмет защиты составляют следующие результаты, полученные лично автором и содержащие элементы научной новизны:

- проведен сравнительный анализ существующих средств и методик анализа информационных рисков и выявлена ограниченность существующих подходов;
- построена математическая модель, описывающая зависимость уровня риска для информационной инфраструктуры организации от объемов финансирования задач информационной безопасности;
- разработана методика анализа рисков информационной инфраструктуры организации;
- формализована задача оптимизации распределения средств, выделенных на обеспечение информационной безопасности, между мероприятиями по защите отдельных информационных ресурсов;
- формализована задача оптимизации финансирования мероприятий информационной безопасности.

Практическая значимость заключается в разработке методики оценки и управления информационными рисками, учитывающей особенности финансирования мероприятий информационной безопасности в коммерческой организации и позволяющей оценить экономическую эффективность бюджета, выделенного на защиту информации.

Область применения результатов исследования. Методики, созданные в рамках диссертационного исследования, могут быть использованы руководством компаний для определения оптимального объема финансирования, выделяемого на защиту информации, а также руководителями подразделений, отвечающих за информационную безопасность, при распределении средств между отдельными мероприятиями. Кроме того, предложенные методики могут быть использованы в работе компаний, осуществляющих аудит информационной безопасности.

Полученные результаты также будут полезны будущим специалистам в области информационной безопасности компаний. Материалы диссертационного исследования могут использоваться в учебном процессе.

Апробация результатов. Результаты исследования докладывались на Всероссийской научно-практической конференции «Математика, информатика, естествознание в экономике и в обществе», проходившей в МФЮА, 22 ноября 2007 года.

Публикации. По материалам диссертационного исследования опубликовано 5 научных работ общим объемом 2 п.л.

Структура работы. Диссертационная работа состоит из введения, трех глав, заключения, библиографического списка и приложений.

ОСНОВНОЕ СОДЕРЖАНИЕ РАБОТЫ

Во введении обоснована актуальность темы диссертационной работы, сформулированы цели и задачи исследования, раскрыта научная новизна и практическая значимость диссертационной работы.

В первой главе «Методологические подходы к анализу и управлению рисками в области защиты информации» рассмотрены различные подходы к анализу и управлению рисками, описаны наиболее распространенные программные средства анализа информационных рисков, а также основные стандарты в области защиты информации и управления рисками.

Анализ информационных рисков представляет собой процесс определения количественной или качественной оценки риска, угроз, уязвимостей, возможного ущерба, а также контрмер и позволяет обеспечивать экономически оправданную информационную безопасность в компании. При этом анализ риска является частью управления рисками, под которым подразумевается процесс управления, устранения или уменьшения вероятности событий, способных негативно воздействовать на информационные ресурсы системы, при условии приемлемой

стоимости средств защиты. В зависимости от требований, предъявляемых к безопасности информации, методы анализа рисков можно разделить на два уровня: базовый и полный. В первом случае достаточно использовать качественные методики оценки риска, не рассматривая ценность ресурсов и не оценивая эффективность контрмер. Во втором случае используют количественные методики оценки риска, позволяющие впоследствии на основе полученных данных решать задачи оптимизации.

Существующие качественные методики анализа информационных рисков достаточно просты в применении, однако при этом они не позволяют получить сколь бы то ни было точные оценки возможных потерь от реализации угроз безопасности информации. Кроме того, такие методики позволяют лишь приблизительно указать наиболее уязвимые места системы и не в состоянии дать какие-либо серьезные рекомендации по модернизации системы защиты, ограничиваясь ссылками на существующие международные и национальные стандарты в области защиты информации и анализа информационных рисков.

Используемые в настоящее время количественные методики анализа рисков, как правило, сводятся к нахождению математического ожидания потерь для некоторого фиксированного состояния информационной системы. При этом они не предполагают возможности выявления участков системы, повышение затрат на защиту которых наиболее существенно повлияет на снижение интегрального риска для системы в целом. Кроме того, зачастую к количественным методам относят так называемые "балльные" методы, в которых качественные оценки заменяются баллами с целью выполнения над ними в дальнейшем некоторых простейших операций, однако такой подход лишь облегчает автоматизацию данных методов и не дает им существенного превосходства над качественными методами.

В настоящее время на рынке существуют несколько десятков программных продуктов для анализа рисков. Все эти средства позволяют автоматизировать работу специалистов в области защиты информации, осуществляющих оценку информационных рисков компании. Данные программные средства также можно разделить на инструментарий базового уровня, позволяющий получить оценку информационной системы предприятия на основе требований международных стандартов, и инструментарий полного анализа рисков, позволяющий не только получать оценки информационных рисков системы, но и выдавать различные рекомендации по снижению риска, проводя анализ эффективности различных контрмер. Однако далеко не во всех случаях полученные рекомендации бывают информативны, так как они в большинстве своем ссылаются на соответствующие положения стандартов, не учитывая специфику исследуемой организации.

Существующие в настоящее время инструментальные средства анализа рисков активно используют в своей работе математическое ожидание величины потерь, связанных с информационными рисками. Однако данная оценка используется исключительно в статическом виде, что приводит к необходимости внесения изменений в построенную модель и повторения значительной части

расчетов при попытке анализа результатов применения тех или иных контрмер. Кроме того, в подавляющем большинстве эти средства ориентированы на оценку безопасности исключительно компьютерных систем обработки информации.

Другим немало важным недостатком данных средств, с точки зрения руководителей компаний, является их сугубо технический характер, основанный на оценке конкретных методов реализации систем защиты в информационных системах без учета стоимости таких решений. Это делает существующие методики слабо пригодными для использования при планировании бюджета подразделений безопасности.

Таким образом, имеет большое научно-практическое значение построение методики расчета уровня информационного риска, учитывающей динамику изменения параметров риска, влияющих на степень защиты информации, как, например, объемы финансирования, выделяемые на обеспечение информационной безопасности в организации.

Во второй главе «Разработка методики анализа рисков для информационной системы организации» построена математическая модель зависимости уровня информационного риска от объема денежных средств, выделяемых на решение задач информационной безопасности, разработана методика анализа уровня риска для информационной инфраструктуры компании, рассмотрены формализованные постановки с указанием методов решения задач определения уровня финансирования мероприятий по защите информации, обеспечивающего снижение общих затрат, связанных с информационными рисками.

В предлагаемой методике выделяются следующие основные этапы:

- инвентаризация и классификация информационных ресурсов компании;
- определение перечня угроз, актуальных для исследуемой информационной системы;
- оценка вероятности реализации угроз и оценка уровня риска для отдельных информационных ресурсов;
- построение интегральной оценки уровня риска для информационной системы в целом;
- разработка рекомендаций по управлению информационными рисками.

На этапе инвентаризации определяется, какая именно информация требует защиты. При этом информация понимается как “сведения о лицах, предметах, фактах, событиях, явлениях и процессах независимо от формы их представления”. Такой подход, в отличие от большинства существующих методик, позволяет рассматривать все многообразие форм представления информации (электронная, печатная, акустическая и др.).

Однако явным недостатком данного определения, не позволяющим использовать его напрямую при анализе защищенности системы, является абстрактность понятия информации. В связи с этим вводится понятие информационного объекта как некоторого объема информации, объединенной по времени, месту и форме ее представления.

Таким образом, задача инвентаризации сводится к составлению перечня всех имеющихся в системе информационных объектов. Такое множество будем обозначать:

$$O = \{o_1, o_2, ..., o_m\},$$

где O – множество информационных объектов системы;

$o_1, o_2, ..., o_m$ – информационные объекты;

m – количество информационных объектов в системе.

Второй основополагающей составляющей риска является угроза защищаемому объекту. В связи с этим следующим шагом при анализе рисков становится определение перечня угроз, актуальных для рассматриваемой информационной системы.

Под угрозой безопасности информации будем понимать потенциально возможное воздействие на информацию, которое прямо или косвенно может нанести урон пользователям или владельцам информации. Основу данного перечня обычно составляют 3 основные типа угроз: конфиденциальности, целостности и доступности информации. Однако работать с таким перечнем практически невозможно. В связи с этим данные угрозы делятся на ряд более простых, учитывающих источник угрозы, характер и тип воздействия и т.п. Так, например, следует разделять угрозы от внешних и внутренних нарушителей, так как меры, необходимые для защиты от них, будут существенно различаться. По аналогичным причинам необходимо разделять угрозы техногенного и антропогенного характера, направленные на технические средства и на персонал, реализуемые локально и удаленно.

Построенное таким образом множество угроз будем обозначать:

$$T = \{t_1, t_2, ..., t_n\},$$

где T – множество угроз информационным объектам системы;

$t_1, t_2, ..., t_n$ – угрозы информационным объектам;

n – общее количество угроз информационным объектам.

После того, как были определены все объекты информационной системы, а также составлен перечень актуальных угроз, становится возможным перейти непосредственно к рассмотрению рисков для данной системы.

Основной целью введения понятия риска является оценка возможных потерь от реализации угроз для некоторого защищаемого ресурса. В связи с этим будем определять риск как математическое ожидание финансовых потерь от реализации некоторой угрозы (группы угроз) для рассматриваемого информационного объекта (набора объектов) за некоторый промежуток времени.

Пусть потери от реализации некоторой угрозы для информационного объекта за рассматриваемый промежуток времени описываются случайной величиной ξ. Очевидно, что данные потери будут состоять из потерь по отдельным опасным событиям, в рамках которых рассматриваемая угроза может реализоваться для данного объекта, причем в общем случае количество таких событий может быть

различным. Кроме того, будем считать, что потери от реализации угрозы при нескольких событиях будут равны сумме потерь по каждому из данных событий:

$$\xi = \upsilon_1 + \upsilon_2 + ... + \upsilon_\mu , \qquad (1)$$

где ξ – случайная величина, описывающая потери от реализации угрозы для информационного объекта за рассматриваемый промежуток времени;

μ – количество опасных событий за рассматриваемый период;

$\upsilon_1,...,\upsilon_\mu$ – случайные величины, описывающие потери в результате опасных событий.

Распределение случайной величины μ может быть восстановлено на основании имеющихся статистических данных или получено методом экспертных оценок, однако в общем случае описать данное распределение не представляется возможным. Вместе с тем очевидно, что ввиду того, что все события в реальном мире длятся в течение некоторого ненулевого времени, то данная случайная величина будет ограничена и ее математическое ожидание будет иметь конечное значение: $M\mu < +\infty$.

Практика показывает, что, как правило, данные события происходят независимо друг от друга в сходных условиях, и, следовательно, случайные величины $\upsilon_1,...,\upsilon_\mu$ имеют одинаковое распределение. Таким образом, обозначив с помощью случайной величины υ потери от реализации угрозы в рамках одного события, получаем:

$$M\xi = M\upsilon \cdot M\mu . \qquad (2)$$

Будем считать, что в рамках каждого опасного события угроза может либо реализоваться, причиняя при этом ущерб, либо нет. Таким образом, случайная величина υ будет иметь дискретное распределение и принимать значения 0 и A с вероятностями $1-p$ и p соответственно (где A – величина денежных потерь организации при реализации рассматриваемой угрозы для информационного объекта; p – вероятность реализации рассматриваемой угрозы для информационного объекта). В результате, выражение для значения риска примет следующий вид:

$$P = M\xi = M\upsilon \cdot M\mu = (0 \cdot (1-p) + A \cdot p) \cdot M\mu = A \cdot p \cdot M\mu , \qquad (3)$$

где P – оценочный уровень риска;

A – величина денежных потерь организации при реализации рассматриваемой угрозы для информационного объекта;

p – вероятность реализации рассматриваемой угрозы для информационного объекта.

Величина A определяется методом экспертных оценок и должна максимально полно включать в себя все денежные убытки, возникающие при реализации угрозы (финансовые потери, связанные с восстановлением информационного ресурса и информационной инфраструктуры, нарушением деятельности организации; ущерб репутации организации; ущерб, от разглашения

конфиденциальной информации и персональных данных и т.д.). Данная величина не зависит от уровня защищенности объекта.

В большинстве существующих методик вероятность p реализации угрозы рассматривается как статическая величина, определяемая экспертом (группой экспертов). Однако такой подход существенно ограничивает возможность использования данной оценки при последующей обработке результатов. Величина p зависит от значительного числа факторов (особенности функционирования организации, уровень квалификации сотрудников, отвечающих за обеспечение режима информационной безопасности, объема финансирования мероприятий по защите информации, и т.п.). Как правило, эти факторы являются либо неизменными, либо носят исключительно технический характер. Особое место в этом ряду занимает объем денежных средств, выделяемых на решение задач, связанных с защитой информации. Кроме того, именно вопрос необходимых объемов денежных средств и их распределения между отдельными направлениями зачастую является слабым звеном во взаимодействии подразделений, занимающихся информационной безопасностью, и руководства компании. В большинстве случаев начальники подразделений безопасности не могут обосновать с экономической точки зрения необходимость выделения конкретных сумм на вопросы обеспечения безопасности и наглядно представить эффект, который будет получен от вложения данных денежных средств в защиту информации. В результате этого, в процессе борьбы с излишними и необоснованными затратами происходит хроническое недофинансирование подразделений, занимающихся безопасностью, что приводит к отсутствию квалифицированных специалистов, закупкам оборудования имеющего низкую надежность и т.д.

Таким образом, можно констатировать, что существует зависимость между вероятностью реализации угрозы и объемом денежных средств, выделяемых на мероприятия по защите рассматриваемого информационного ресурса от некоторой угрозы. Таким образом, представим p в виде:

$$p = g(x), \tag{4}$$

где x – объем денежных средств, выделенных на реализацию мероприятий по обеспечению защиты информационного ресурса от некоторой угрозы;

$g(x)$ – функция, описывающая вероятность реализации угрозы для некоторого информационного ресурса в зависимости от объема средств, вкладываемых в мероприятия по ее предотвращению. При этом для функции $g(x)$ должно выполняться неравенство: $0 \le g(x) \le 1$.

В каждом конкретном случае вид и параметры функции могут определяться одним из двух способов. В первом случае функция может быть построена путем обработки имеющихся статистических данных, однако такая информация может иметься только у крупных фирм, специализирующихся в области аудита информационной безопасности. Во всех остальных случаях применяются экспертные методы, при этом возможно задание экспертом или экспертной

группой как непосредственного вида функции, так и отдельных ее значений для последующего применения к ним методов аппроксимации. Кроме того, существенную помощь эксперту может оказать база данных, созданная на основе статистических наблюдений и содержащая различные функции $g(x)$ для ряда типовых ситуаций.

Чаще всего зависимость $g(x)$ носит экспоненциальный характер, однако следует помнить, что в общем случае можно лишь констатировать, что функция $g(x)$ является невозрастающей и с увеличением значения аргумента будет стремиться к некоторой неотрицательной константе.

Более точно описать функцию не представляется возможным, так как ее вид будет существенным образом меняться в зависимости от типа защищаемого информационного ресурса, технических средств и организационных мер, которые могут быть использованы для защиты и т.д.

Представленные уточнения свойств функции $g(x)$ в значительной степени характерны для ситуации, когда для противодействия угрозам используются однотипные мероприятия, сходным образом воздействующие на угрозу. Кроме того, отсутствие диверсификации при рассмотрении объемов финансирования средств защиты делает подобный подход не всегда допустимым при переходе к анализу систем, состоящих более чем из одного объекта, когда одни и те же мероприятия могут влиять на уровень защищенности сразу нескольких объектов от ряда угроз. Ярким примером подобного влияния может являться квалификация сотрудников подразделения безопасности, которая в значительной степени зависит от уровня заработной платы.

В этом случае целесообразно рассмотреть функцию $g(\overline{x})$, зависящую от вектора значений, в котором каждая компонента соответствует конкретной статье финансирования мероприятий по защите. Более того, при рассмотрении сложных систем возможно использование вектора $\overline{x}$, содержащего затраты на все возможные типы мероприятий по защите, актуальные для данной системы, для всех пар "информационный объект – угроза".

Для реализации такого подхода необходимо создать максимально полный перечень всех возможных статей расходов, связанных с обеспечением информационной безопасности системы:

$$S = \{s_1, s_2, ..., s_n\},$$

где S – множество возможных контрмер;

$s_1, s_2, ..., s_q$ – контрмеры;

q – количество возможных контрмер.

Следует отметить, что в данный перечень должны входить все затраты, влияющие на уровень информационной безопасности системы, независимо от того, включаются ли они в бюджет подразделений информационной безопасности или находятся в ведении других структур.

Кроме того, для каждой из контрмер могут существовать ограничения возможных затрат как сверху, так и снизу:

$$\forall i \in \overline{1,q} \quad v_i \le x_i \le w_i ,$$

где x_i – объем денежных средств, выделяемых на реализацию i-ой контрмеры;

v_i – минимальный объем денежных средств, который может быть потрачен на реализацию i-ой контрмеры ($v_i \ge 0$);

w_i – максимальный объем денежных средств, который может быть потрачен на реализацию i-ой контрмеры ($w_i < +\infty$).

Таким образом, функция $g(\bar{x})$ будет зависеть сразу от нескольких переменных, при этом большинство переменных могут являться фиктивными. Так, например, мероприятия, обеспечивающие защиту от пожара, не будут оказывать никакого влияния на вероятность появления в системе компьютерных вирусов. Что же касается существенных переменных, то по каждой из них данная функция будет невозрастающей.

Часто опасную ситуацию можно методом декомпозиции разбить на несколько отдельных событий, которые могут приводить к реализации угрозы либо по отдельности, либо в комплексе. При этом для каждого из событий может быть построена отдельная функция, описывающая вероятность реализации угрозы, а затем из этих элементарных функций в соответствии с правилами теории вероятностей будет составлена одна общая формула.

Таким образом, в соответствии с ранее введенным определением значение риска P будет рассматриваться как функция:

$$P(\bar{x}) = M\xi = M\upsilon \cdot M\mu = A \cdot M\mu \cdot g(\bar{x}) , \qquad (5)$$

где $P(\bar{x})$ – уровень риска для информационного объекта по некоторой угрозе, выраженный в денежных единицах;

$\bar{x}$ – вектор, описывающий объем денежных средств, выделенных на реализацию мероприятий по обеспечению защиты информационного объекта, а также их распределение между отдельными задачами;

$M\mu$ – математическое ожидание количества опасных событий за рассматриваемый промежуток времени;

A – ущерб от реализации рассматриваемой угрозы для информационного объекта;

$g(\bar{x})$ – функция, описывающая вероятность реализации угрозы для информационного объекта в зависимости от объема средств, вкладываемых в мероприятия, связанные с информационной безопасностью.

Полученное выше выражение для уровня риска является достаточно общим и может быть применено как к отдельному объекту, так и к большим наборам информационных объектов. Так, задав уровень ущерба и функцию, описывающую вероятность реализации угрозы для такого набора объектов, с

помощью данной формулы получим оценку риска. Однако на практике использование подобного подхода для сколь бы то ни было значительных по объему информационных структур будет крайне затруднительным, так как при этом потребуется учесть большое количество различных факторов, влияющих на данную зависимость.

Напротив, для отдельных информационных объектов подобные функции могут быть построены достаточно легко, так как для конкретной пары "информационный объект – угроза" не составит значительного труда оценить как вероятность реализации данной угрозы, так и возникающий при этом экономический ущерб. Затем, определив указанные параметры для каждой пары, можно получить интегральную оценку уровня риска и для информационной системы в целом. Однако даже для достаточно небольшой организации количество таких пар будет крайне велико. В связи с этим необходимо предусмотреть меры, которые позволят снизить трудоемкость процесса оценки.

Для вычисления уровня риска для пары "информационный объект – угроза" необходимо определить три исходных параметра: ущерб от реализации угрозы, количество опасных событий за рассматриваемый период времени и вероятность реализации угрозы в рамках одного события.

Как было показано выше, размер ущерба от некоторой угрозы является характеристикой самого информационного объекта и не зависит от каких-либо внешних факторов. Таким образом, необходимо единожды зафиксировать данное значение для каждой пары. В диссертационной работе был предложен ряд мер, позволяющих снизить трудоемкость процесса оценки размера ущерба. В результате реализации данного этапа получаем набор значений $\hat{A}_{i,j}$, которые характеризуют величину денежных потерь организации при реализации j-ой угрозы для i-го информационного объекта.

Рассмотрим оценки вероятности реализации угроз для различных информационных объектов. Очевидно, что в основном данный параметр будет зависеть от формы представления информации, способов ее хранения и обработки, а также мер, предпринимаемых для защиты. При этом можно считать, что содержание объекта не будет иметь никакого значения, так как воздействие при реализации угрозы в равной степени коснется всех информационных объектов, хранящихся и обрабатываемых вместе.

Таким образом, имеет смысл объединить информационные объекты в блоки на основе их формы представления, мест хранения и обработки, а также мер защиты. Следствием такого разбиения будет являться то, что для всех объектов, входящих в один информационный блок, угрозы реализуются одновременно, а меры защиты, предпринимаемые для защиты одного из объектов, автоматически будут распространяться и на все остальные, входящие в данный блок. Кроме того, параметр $M\mu$, описывающий количество опасных событий за рассматриваемый период времени, также будет относиться к информационному блоку.

Переход от анализа риска для отдельных информационных объектов к информационным блокам позволит существенно снизить трудоемкость. Вместе с тем это не приведет к снижению точности вычислений, так как именно информационный блок является минимальным элементом, для которого реализуется угроза.

Следует отметить, что один и тот же объект при рассмотрении различных угроз может входить более чем в один блок. Так, например, информация, хранящаяся на сервере, будет рассматриваться как отдельный блок при анализе угроз, связанных с сетевой безопасностью, а в том случае, если несколько серверов располагаются в пределах одного помещения, такая угроза как пожар потребует объединения в один блок всех информационных ресурсов, находящихся в данной комнате.

Введем обозначения:

$B = \{B_1, B_2, ..., B_l\}$, $\forall B_i \in B(i = \overline{1,l})\ B_i \subset O$, $B_1 \bigcup B_2 \bigcup ... \bigcup B_l = O$,

где B – множество информационных блоков;

$B_1, B_2, ..., B_l$ – информационные блоки;

O – множество информационных объектов системы;

l – количество информационных блоков.

В соответствии с построением информационных блоков функция, описывающая вероятность реализации угрозы, а также параметр, характеризующий общее количество опасных событий, будут общими для всех элементов блока, а значит, и для блока в целом. Как было сказано выше, данные параметры могут быть определены либо методом экспертных оценок, либо на основе статистических данных.

Третьим параметром информационного блока, необходимым для определения уровня риска, является размер ущерба от реализации угрозы. Воспользуемся допущением, что при реализации угрозы для нескольких информационных объектов потери по каждому из объектов будут независимыми друг от друга. Таким образом, значение ущерба для информационного блока в целом будет равно сумме потерь по всем объектам, входящим в данный блок. Кроме того, следует помнить, что хранение и обработка информации невозможны без аппаратного обеспечения, следовательно, при оценке ущерба необходимо также учитывать средства, требующиеся для восстановления данного оборудования.

Пусть $\forall r = \overline{1,l} \quad I_r = \{\, i, \textit{таких что } o_i \in B_r \}$,

тогда $\forall B_r \in B(r = \overline{1,l}), \forall j = \overline{1,n} \quad A_{r,j} = \sum_{i \in I_r} \hat{A}_{i,j} + A^h_{r,j}$,

где $\hat{A}_{i,j}$ – величина денежных потерь организации при реализации j-ой угрозы для i-го информационного объекта;

$A^h_{r,j}$ – стоимость восстановления оборудования, необходимого для хранения и обработки информационных объектов, входящих в r-ый информационный

блок, и выводимого из строя при реализации j-ой угрозы для данного блока. При этом в случае, когда негативному воздействию подвергается только информационная составляющая, а оборудование сохраняет свои эксплуатационные свойства, значение $A^h_{r,j}$ будет равно 0.

В результате, становится возможным представить уровень риска для всех пар "информационный блок – угроза" в виде произведения трех величин: ущерба от реализации угрозы для данного блока, наиболее вероятного количества опасных событий за рассматриваемый период и функции, описывающей вероятность реализации угрозы в рамках единичного опасного события.

Таблица 1.

Определение функции риска для информационных блоков

Информационные объекты	Угрозы			
	t_1	t_2	...	t_n
B_1	$A_{1,1}M\mu_{1,1} \cdot g_{1,1}(\bar{x})$	$A_{1,2}M\mu_{1,2} \cdot g_{1,2}(\bar{x})$	...	$A_{1,n}M\mu_{1,n} \cdot g_{1,n}(\bar{x})$
B_2	$A_{2,1}M\mu_{2,1} \cdot g_{2,1}(\bar{x})$	$A_{2,2}M\mu_{2,2} \cdot g_{2,2}(\bar{x})$	...	$A_{2,n}M\mu_{2,n} \cdot g_{2,n}(\bar{x})$
...	...	...	...	...
B_l	$A_{l,1}M\mu_{l,1} \cdot g_{l,1}(\bar{x})$	$A_{l,2}M\mu_{l,2} \cdot g_{l,2}(\bar{x})$	...	$A_{l,n}M\mu_{l,n} \cdot g_{l,n}(\bar{x})$

Подставив в полученные выражения в качестве аргумента вектор, описывающий объемы денежных средств, расходуемых на проведение мероприятий, связанных с защитой информации, получим наиболее вероятный объем потерь компании по данному информационному блоку от рассматриваемой угрозы.

Полученные значения представляют собой набор оценок уровня риска по разрозненным блокам информационной инфраструктуры компании. Такое представление может быть полезно для решения некоторых локальных задач, однако не позволяет представить картину информационных рисков для организации в целом. В связи с этим необходимо перейти от частных значений к некоторому интегральному показателю.

Вернемся к первоначальному представлению значения объема потерь компании от угроз информационной безопасности в виде случайной величины. Определим потери компании, связанные с информационной безопасностью следующим образом:

$$\xi = \sum_{i=1}^{l}\sum_{j=1}^{n}\xi_{i,j}, \qquad (6)$$

где ξ – потери компании от реализации угроз информационной безопасности;

$\xi_{i,j}$ – потери, возникающие при реализации j-ой угрозы для i-го информационного блока.

Следовательно, уровень информационного риска для системы в целом будет иметь следующий вид:

$$M\xi = M(\sum_{i=1}^{l}\sum_{j=1}^{n}\xi_{i,j}) = \sum_{i=1}^{l}\sum_{j=1}^{n}M\xi_{i,j}\,. \qquad (7)$$

Подставив в данную формулу выражение для $M\xi_{i,j}$, получим:

$$P(\bar{x}) = \sum_{i=1}^{l}\sum_{j=1}^{n}A_{i,j}\cdot M\mu_{i,j}\cdot g_{i,j}(\bar{x}), \qquad (8)$$

где $P(\bar{x})$ – уровень риска для информационной системы в целом;

$\bar{x}$ – средства, выделяемые на информационную безопасность с учетом их распределения по отдельным статьям расходов;

$A_{i,j}$ – ущерб от реализации j-ой угрозы для i-го информационного блока;

$M\mu_{i,j}$ – математическое ожидание количества событий, способных привести к реализации j-ой угрозы для i-го информационного блока;

$g_{i,j}(\bar{x})$ – функция, описывающая зависимость вероятности реализации j-ой угрозы для i-го информационного блока в зависимости от объема ассигнований на мероприятия по предотвращению данной угрозы.

Полученная функция $P(\bar{x})$ однозначно определяет значения информационного риска для компании в зависимости от объемов финансирования, выделяемых на защиту информации, а также распределения данных средств между отдельными задачами информационной безопасности. Кроме того, представление результата именно в денежной форме позволяет наглядно представить предполагаемые потери и в зависимости от полученных данных принимать обоснованные решения по управлению компанией.

Выявленные в процессе анализа рисков функциональные зависимости позволяют перейти к следующему, не менее важному этапу – управлению информационными рисками. Основной целью данного этапа является выработка рекомендаций по перечню управляющих воздействий (определение объемов финансирования задач информационной безопасности), направленных на снижение уровня риска. Для этого рассмотрим задачи оптимизации, которые позволят определить наиболее эффективные управляющие воздействия, обеспечивающие минимизацию риска для информационной системы организации в целом.

Так, одним из наиболее актуальных вопросов будет являться нахождение такого распределения имеющихся денежных средств между отдельными задачами информационной безопасности, при котором значение информационного риска для организации в целом будет минимальным.

В качестве целевой функции выберем функцию, описывающую значение информационного риска для организации в целом, т.е.:

$$\sum_{i=1}^{l}\sum_{j=1}^{n} A_{i,j} \cdot M\mu_{i,j} \cdot g_{i,j}(\overline{x}) \to \min . \qquad (9)$$

Рассмотрим ограничения на значения аргументов данной функции, которые необходимо учесть при решении задачи. Во-первых, значения аргументов x_i, должны удовлетворять ограничениям, заданным для данной контрмеры, а, во-вторых, их сумма не должна превосходить общего объема денежных средств D, выделенных на информационную безопасность:

$$\begin{gathered} v_i \le x_i \le w_i,\ i \in \overline{1,q} \\ \sum_{i=1}^{q} x_i \le D. \end{gathered} \qquad (10)$$

Таким образом, задача оптимизации будет иметь следующий вид:

$$\begin{gathered} \sum_{i=1}^{l}\sum_{j=1}^{n} A_{i,j} \cdot M\mu_{i,j} \cdot g_{i,j}(\overline{x}) \to \min \\ \begin{cases} \sum_{i=1}^{q} x_i \le D \\ v_i \le x_i \le w_i,\ i \in \overline{1,q}. \end{cases} \end{gathered} \qquad (11)$$

Данная задача относится к классу задач нелинейного программирования с линейными ограничениями, для решения которых разработан целый ряд различных методов. Так, например, для случая, когда целевая функция будет выпуклой, данная задача переходит в класс задач выпуклого программирования и для ее решения могут быть использованы методы Зойтендейка, условного градиента Франка-Вульфа и др.

Решение данной задачи позволит эффективно распределить средства, выделенные на информационную безопасность, между отдельными направлениями и добиться минимально возможного уровня риска при заданном объеме финансирования.

Еще одной задачей, которая становится доступной для решения с использованием построенной модели, является задача нахождения экономически обоснованного объема денежных средств, необходимого для обеспечения информационной безопасности.

Очевидно, что общие затраты на информационную безопасность будут складываться из непосредственных расходов на проведение мероприятий по защите информации ($\overline{x}$), а также значений информационного риска ($P(\overline{x})$), который показывает наиболее вероятный размер ущерба. Таким образом, в общем виде функция общих затрат будет иметь вид:

$$H(\overline{x}) = P(\overline{x}) + \sum_{i=1}^{q} x_i . \qquad (12)$$

Следовательно, для нахождения экономически оправданного уровня финансирования необходимо решить задачу оптимизации, в которой критерием будет являться функция общих затрат $H(\bar{x})$, а в качестве ограничений будут выступать допустимые границы значений компонент вектора $\bar{x}$:

$$\sum_{i=1}^{l}\sum_{j=1}^{n} A_{i,j} \cdot M\mu_{i,j} \cdot g_{i,j}(\bar{x}) + \sum_{i=1}^{q} x_i \to \min$$
$$v_i \le x_i \le w_i, i \in \overline{1,q}. \qquad (13)$$

Данная задача так же, как и предыдущая, относится к классу задач нелинейного программирования и может быть решена аналогичными методами.

Решение данной задачи позволит определить оптимальный объем финансирования, выделяемого на информационную безопасность, а также распределение данных средств между отдельными направлениями защиты.

Следует отметить, что предложенная методика анализа рисков позволяет не только построить экономически обоснованную систему информационной безопасности, но и позволяет техническим специалистам обосновать с экономической точки зрения необходимость предоставления тех или иных денежных средств.

В третьей главе «Анализ защищенности информационной системы ВУЗа» автором проведен анализ информационных рисков для участка информационной системы ВУЗа. Целью данной главы является не проведение полномасштабного исследования защищенности информационной системы ВУЗа, а лишь демонстрация применимости методики анализа рисков, предложенной во второй главе, а также в доказательстве эффективности получаемых с ее помощью управленческих решений.

В качестве объекта исследования был выбран участок информационной системы ВУЗа, включающий в себя систему компьютерных классов с расположенным в нем оборудованием, а также помещение серверной с размещенными в ней серверами, связанными с работой компьютерных классов.

С привлечением специалистов, занимающихся эксплуатацией данной системы, был составлен перечень информационных объектов. После чего был составлен список актуальных для данной системы угроз с учетом возможных причин их возникновения:

1. нарушение правил эксплуатации, приводящее к выходу из строя оборудования;
2. нестабильность работы (сбой);
3. взлом системы с получением полного контроля над ней;
4. вредоносное программное обеспечение;
5. уничтожение;
6. утечка;
7. хищение;

8. техногенные и природные катастрофы (пожар, наводнение, скачки напряжения в электросети и т.п.).

Далее, в соответствии с методикой, для каждого из объектов были получены оценки ущерба от различных угроз, а затем объекты были объединены в следующие информационные блоки:

1. компьютер преподавателя в компьютерном классе;
2. компьютер студента в компьютерном классе;
3. коммутационное оборудование в компьютерном классе;
4. материалы преподавателя в бумажной форме в компьютерном классе;
5. материалы студента в бумажной форме в компьютерном классе;
6. информация в акустической форме в компьютерном классе;
7. сервер, обеспечивающий функционирование локальной сети, в серверной комнате;
8. сервер СДО в серверной комнате;
9. сервер, обеспечивающий доступ пользователей в сеть Интернет, в серверной комнате;
10. коммутационное оборудование в серверной комнате;
11. информация в бумажной форме в серверной комнате;
12. информация в акустической форме в серверной комнате;
13. помещение компьютерного класса;
14. помещение серверной комнаты.

Затем был составлен перечень контрмер, которые могут быть применены в данной системе с целью снижения вероятности реализации угроз:

1. закупка оборудования рабочих станций;
2. закупка оборудования серверов;
3. закупка коммутационного оборудования;
4. использование антивирусных средств на рабочих станциях;
5. использование антивирусных средств на серверах;
6. использование локальных средств сетевой защиты на рабочих станциях;
7. использование локальных средств сетевой защиты на серверах;
8. оплата работы администраторов сети;
9. организация обучения преподавателей компьютерной грамотности;
10. противопожарная защита компьютерных классов;
11. противопожарная защита серверной;
12. техническая защита помещений;
13. физическая охрана помещений.

Ввиду отсутствия статистических данных были составлены анкеты, в которых экспертам было предложено оценить количество опасных ситуаций и вероятность их негативного исхода по всем блокам для каждой из угроз при различных объемах финансирования, выделяемого на применение перечисленных контрмер.

На основе полученных оценок с использованием математического программного пакета Mathcad 14.0 были составлены функции, описывающие уровень риска для различных информационных блоков по всем угрозам. Так,

например, для информационного блока – "компьютер преподавателя" и угрозы – "нарушение правил эксплуатации..." была получена следующая формула:

$$P_{1,1}(\bar{x}) = (0{,}333 \cdot x_1 + 16000) \cdot (0{,}049 \cdot e^{-2.617\times10^{-6}\cdot x_8} + 8{,}3\times10^{-4} + 0{,}025 \cdot e^{-1.466\times10^{-6}\cdot x_9} + \\ + 8{,}208\times10^{-3} - (0{,}049 \cdot e^{-2.617\times10^{-6}\cdot x_8} + 8{,}3\times10^{-4}) \cdot (0{,}025 \cdot e^{-1.466\times10^{-6}\cdot x_9} + 8{,}208\times10^{-3})), \quad (14)$$

где $P_{1,1}(\bar{x})$ – функция, описывающая уровень риска для данной пары "информационный блок - угроза";

x_8 и x_9 – компоненты вектора $\bar{x}$, описывающие объемы денежных средств, выделенных на "оплату работы администраторов" и "организацию обучения преподавателей..." соответственно.

На следующем этапе анализа путем суммирования полученных функций была построена функциональная зависимость $P(\bar{x})$, описывающая уровень риска для системы в целом.

Ввиду отсутствия данных о текущих объемах финансирования задач, связанных с информационной безопасностью, оценить текущий уровень информационного риска не представляется возможным. Таким образом, сразу была рассмотрена задача определения оптимального уровня финансирования статей расходов, влияющих на уровень безопасности системы.

Общие затраты на информационную безопасность будут складываться из непосредственных расходов на проведение мероприятий по защите информации $\sum_{i=1}^{13} x_i$, а также значений информационного риска для каждой пары $P_{i,j}(\bar{x})$, который представляет наиболее вероятный размер ущерба за рассматриваемый период (1 год). Таким образом, получаем следующую задачу оптимизации:

$$\sum_{i=1}^{14}\sum_{j=1}^{8} P_{i,j}(\bar{x}) + \sum_{i=1}^{13} x_i \to \min \\ v_i \le x_i,\ i \in \overline{1,13}. \quad (15)$$

Данная задача относится к классу задач нелинейного программирования. Для ее решения был использован программный продукт Mathcad 14.0.

$G(X) := P(X) + X_1 + X_2 + X_3 + X_4 + X_5 + X_6 + X_7 + X_8 + X_9 + X_{10} + X_{11} + X_{12} + X_{13}$

$Xmin_1 := 857040$ $Xmin_2 := 9000$ $Xmin_3 := 2460$ $Xmin_4 := 0$ $Xmin_5 := 0$ $Xmin_6 := 0$ $Xmin_7 := 0$ $Xmin_8 := 0$

$Xmin_9 := 0$ $Xmin_{10} := 8000$ $Xmin_{11} := 200$ $Xmin_{12} := 0$ $Xmin_{13} := 0$

$XO := \mathrm{Minimize}(G, X)$

$G(XO) = 3.439 \times 10^6$ $P(XO) = 8.361 \times 10^5$ $G(Xmin) = 3.906 \times 10^8$ $P(Xmin) = 3.897 \times 10^8$

$\sum_{i=1}^{13} XO_i = 2.603 \times 10^6$ $\sum_{i=1}^{13} Xmin_i = 8.767 \times 10^5$ $\frac{G(Xmin)}{G(XO)} = 113.6$

Таким образом, при эффективном использовании контрмер возможно удержание среднегодовых затрат на информационную безопасность на уровне 3 439 тыс.руб. Причем 836,1 тыс.руб. из данной суммы будут приходиться на

потери от реализации угроз, а 2 603 тыс.руб. – на финансирование мероприятий информационной безопасности. Данные средства должны быть распределены между рассматриваемыми статьями бюджета информационной безопасности следующим образом:

Закупка оборудования рабочих станций:	$XO_1 = 8.57 \times 10^5$	Оплата работы администраторов сети:	$XO_8 = 1.096 \times 10^6$
Закупка оборудования серверов:	$XO_2 = 9 \times 10^3$	Организация обучения преподавателей компьютерной грамотности:	$XO_9 = 0$
Закупка коммутационного оборудования	$XO_3 = 2.46 \times 10^3$	Противопожарная защита компьютерных классов	$XO_{10} = 8 \times 10^3$
Использование антивирусных средств на серверах:	$XO_5 = 1.93 \times 10^3$	Противопожарная защита серверной	$XO_{11} = 200$
Использование локальных средств сетевой защиты на рабочих станциях:	$XO_6 = 0$	Техническая защита помещений:	$XO_{12} = 3.717 \times 10^3$
Использование локальных средств сетевой защиты на серверах	$XO_7 = 9.885 \times 10^3$	Физическая охрана помещений:	$XO_{13} = 6.15 \times 10^5$

Если на мероприятия по информационной безопасности выделять только обязательный минимум средств, необходимый для функционирования информационной системы, то значение потерь составит 390 600 тыс.руб., что в 113,6 раз больше, чем при найденном решении. Таким образом, выделяя ежегодно 2 603 тыс.руб. на обеспечение информационной безопасности, при оптимальном распределении данных средств можно добиться сокращения среднегодовых затрат в данной области на 387 160 тыс.руб.

Данный пример демонстрирует возможности использования построенной методики оценки риска в задачах оптимизации, а также в создании экономически оправданной политики информационной безопасности. Ее применение позволит заложить четкие методологические основы в процесс планирования объема бюджета на информационную безопасность за счет выбора системы контрмер, которая обладала бы наилучшим соотношением цена-качество.

ОСНОВНЫЕ ВЫВОДЫ И РЕЗУЛЬТАТЫ ИССЛЕДОВАНИЯ

Материалы, изложенные в диссертации, позволяют сделать следующие выводы:

1. Сравнительный анализ наиболее распространенных методик и программных продуктов, предназначенных для оценки уровня информационного риска, показал, что в подавляющем большинстве случаев специфика исследуемой информационной системы не учитывается, а анализ уровня риска строится на сравнении используемых в организации мер защиты с требованиями, прописанными в соответствующих стандартах.
2. Анализ методик количественной оценки информационных рисков, а также основанных на них программных продуктов показал, что при оценке риска используются исключительно статические оценки вероятности реализации угроз, что приводит к необходимости

повторного проведения расчетов для проверки эффективности различных вариантов контрмер.

3. Анализ общей направленности наиболее распространенных методик и программ оценки информационных рисков показал, что на современном этапе развития данной области наибольшее внимание уделяется техническим средствам и организационно-административным мерам защиты информации, при этом практически не рассматривается вопрос об определении требуемого уровня финансирования для реализации указанных мер.
4. Проведенный комплекс исследований текущего состояния дел в области анализа информационных рисков позволяет сделать вывод о необходимости создания новой методики анализа информационных рисков, позволяющей эффективно управлять финансовыми активами для обеспечения экономически обоснованного уровня защиты информации.
5. Предложен способ оценки уровня риска для информационного объекта с помощью функции, в качестве аргументов которой выступает объем денежных средств, выделяемых на защиту объекта, а также их распределение между отдельными мероприятиями информационной безопасности.
6. Разработана математическая модель зависимости денежного выражения информационного риска для организации от объемов финансирования отдельных статей бюджета, влияющих на уровень информационной безопасности. Данная модель может быть использована при решении различных задач, связанных с анализом влияния бюджета информационной безопасности на общий уровень информационного риска для данной системы.
7. На основе предложенной математической модели разработана методика оценки текущего уровня информационного риска для организации, а также рассмотрены задачи оптимального распределения денежных средств, выделяемых на защиту информационных ресурсов, между отдельными задачами информационной безопасности, включая задачу определения экономически обоснованного объема финансирования, выделяемого на защиту информации.
8. Рассчитан уровень информационного риска для участка информационной системы ВУЗа и предложен оптимальный вариант распределения денежных средств между отдельными задачами, связанными с защитой информации. Результаты расчета показывают, что отсутствие мер по защите информации может привести к существенным финансовым потерям, в то же время эффективное планирование статей бюджета, влияющие на информационную безопасность, позволяет более чем на порядок снизить расходы, связанные с информационными рисками.
9. Показана практическая значимость и продемонстрирована эффективность применения функциональной зависимости риска от объемов денежных

средств при решении задачи оптимизации финансирования мероприятий информационной безопасности.

10. Предложенная методика может быть использована компаниями, осуществляющими разработку инструментальных средств анализа информационных рисков, организациями, занимающимися непосредственной проверкой защищенности информационных систем, а также страховыми компаниями, предлагающими услуги в области страхования информационных рисков.

СПИСИОК ОПУБЛИКОВАННЫХ РАБОТ

Список опубликованных работ по теме диссертационного исследования:

В изданиях, рекомендованных ВАК:

1. Немиткина В.В. Применение методов оптимизации при анализе и управлении информационными рисками // Экономика и математические методы, 2008, том 44, №2. (1, п.л.)
2. Мастяева И.Н., Немиткина В.В. Оптимизация затрат организаций, связанных с информационными рисками // Экономические науки. Научно-информационный журнал. №11(36), 2007. (авторские – 0,3 п.л.)

В других научных изданиях:

3. Немиткина В.В. Методика оценки информационного риска в коммерческой организации // Математика, информатика, естествознание в экономике и в обществе/ Труды международной научно-практической конференции. – М.: МФЮА, 2007. (0,3 п.л.)
4. Немиткина В.В. Информационные риски системы дистанционного образования вуза: классификация угроз, этапы оценки // Роль бизнеса в трансформации российского общества: сб. научных трудов / отв. ред. Ю.Б. Рубин. В 2 т. Т. 1. – М.: Московская финансово-промышленная академия; Маркет ДС, 2007. (0,2 п.л.)
5. Немиткина В.В. Проблемы оценки информационных рисков // Система бизнеса/ Под ред. профессора Ю.Б. Рубина. Московская финансово-промышленная академия. М.: Маркет ДС, 2006. Вып. 2. (0,2 п.л.)

Подписано к печати 24.12.08

Формат издания 60x84/16 | Бум. офсетная №1 | Печать офсетная

Печ.л. 1,5 | Уч.-изд.л. 1,4 | Тираж 100 экз.

Заказ № 7846

Типография издательства МЭСИ. 119501, Москва, Нежинская ул., 7